

Shield Gates: A Multi-Layer AI-Based Secure Email Gateway for Phishing Detection

Abstract— Email phishing remains one of the most critical cybersecurity threats, causing financial losses, credential theft, and malware infections. Traditional email security mechanisms often rely on single-layer detection techniques, making them vulnerable to sophisticated phishing attacks that exploit multiple evasion strategies. This paper presents Shield Gates, a multi-layer AI-based Secure Email Gateway designed to detect and block malicious emails before they reach the internal mail server. The proposed architecture combines header authentication analysis using SPF, DKIM, and DMARC, machine learning-based header classification with XGBoost, natural language processing using RoBERTa and TF-IDF for email body analysis, and dynamic attachment inspection through the CAPEv2 sandbox. A centralized decision engine integrates the outputs of all detection layers using adaptive risk scoring and deterministic security rules to generate the final classification decision. The system was implemented using Postfix, Dovecot, Python, and Ubuntu virtual machines to simulate a real-world enterprise email infrastructure. Experimental evaluation on a balanced dataset of 14,510 emails achieved a validation ROC-AUC of 0.9984, a Precision of 98.68%, a Recall of 96.42%, and a False Positive Rate of 1.64%. The results demonstrate that the proposed multi-layer architecture provides accurate phishing detection while maintaining a low false positive rate, making Shield Gates a practical and scalable solution for modern enterprise email security.

Keywords— Secure Email Gateway, Phishing Detection, Email Security, Machine Learning, Natural Language Processing, XGBoost, RoBERTa, CAPEv2.

I. INTRODUCTION

Email has become one of the primary communication channels for individuals and organizations, making it a major target for cyberattacks. Among these threats, phishing emails remain one of the most dangerous due to their ability to steal credentials, distribute malware, and compromise sensitive information. As phishing techniques continue to evolve, traditional email filtering solutions struggle to detect sophisticated attacks that exploit forged identities, malicious attachments, and deceptive content.

Existing email security solutions often focus on a single detection technique, such as header authentication, content analysis, or attachment scanning. While these approaches are effective against certain attacks, they may fail to identify complex phishing emails that combine multiple attack vectors. This limitation highlights the need for a comprehensive and multi-layered email protection framework.

To address this challenge, this paper presents **Shield Gates**, a multi-layer AI-based Secure Email Gateway that integrates header authentication analysis (SPF, DKIM, and DMARC), machine learning-based header classification using XGBoost, natural language processing using RoBERTa and TF-IDF for email body analysis, and

dynamic attachment inspection through the CAPEv2 sandbox. The outputs of these components are combined by a centralized decision engine to provide accurate and reliable phishing detection before emails reach the internal mail server.

The main contributions of this work include the design of an integrated Secure Email Gateway, the combination of multiple detection techniques within a unified architecture, and the implementation of a real-world filtering system based on Postfix and Dovecot. Experimental results demonstrate that the proposed system achieves high phishing detection performance while maintaining a low false positive rate, making it suitable for practical enterprise email protection.

II. RELATED WORK

Email phishing detection has attracted significant research interest due to the rapid evolution of phishing attacks and their increasing impact on individuals and organizations. Existing studies have explored machine learning, deep learning, and hybrid techniques to improve phishing detection by analyzing different email components, including headers, textual content, and metadata.

Zhang et al. [1] proposed a malicious email detection framework that combines static email features with **TF-IDF** textual representations. Using a large-scale dataset containing more than 660,000 emails, their **Random Forest** classifier achieved an accuracy of **99.97%**. The framework demonstrated excellent classification performance. However, it relies mainly on static feature analysis and does not support dynamic attachment inspection or real-time Secure Email Gateway deployment.

Chang et al. [2] introduced a hybrid phishing detection model that integrates **BERT** with **TF-IDF** to improve contextual understanding of email content. Their results showed that combining transformer-based language models with traditional text features significantly enhances phishing detection performance. Nevertheless, the proposed approach focuses only on email body analysis and does not consider sender authentication or attachment behavior.

Alhuzali et al. [3] conducted a comprehensive evaluation of multiple machine learning and deep learning models using several phishing email datasets. Their findings showed that transformer-based models, particularly **BERT** and **RoBERTa**, consistently outperform conventional machine learning algorithms. However, the study mainly compares model performance and does not propose an integrated email security architecture.

Qi et al. [4] developed an ensemble learning framework combined with undersampling techniques to improve phishing email detection on imbalanced datasets. Their method achieved higher classification performance while reducing prediction bias. Despite these improvements, the framework is limited to email classification and does not include authentication verification, attachment inspection, or gateway-level filtering.

Dewis and Viana [5] proposed **Phish Responder**, a hybrid machine learning framework for phishing and spam email detection. Their system combines multiple machine learning techniques to improve classification accuracy. Although the framework demonstrates promising results, it lacks sender authentication mechanisms, dynamic malware analysis, and centralized decision-making capabilities.

Although previous studies have reported high phishing detection accuracy, most existing approaches focus on a single aspect of email analysis, such as textual content, handcrafted features, or machine learning classification. Few studies integrate **SPF**, **DKIM**, and **DMARC** authentication [6]–[8] with header analysis, **RoBERTa**-based content classification [10], **XGBoost**-based feature analysis [9], dynamic **CAPEv2** sandboxing, and gateway-level filtering within a unified architecture. To address these limitations, the proposed **Shield Gates** system combines these complementary security mechanisms through a centralized decision engine, providing a comprehensive and practical solution for detecting sophisticated phishing emails before they are delivered to the internal mail server.

III. PROPOSED SYSTEM

A. System Overview

The proposed **Shield Gates** system is a multi-layer AI-based Secure Email Gateway designed to analyze incoming emails before they reach the internal mail server. Instead of relying on a single detection mechanism, the system combines sender authentication, header analysis, natural language processing, attachment sandboxing, and centralized decision-making to provide comprehensive protection against phishing attacks.

B. System Architecture

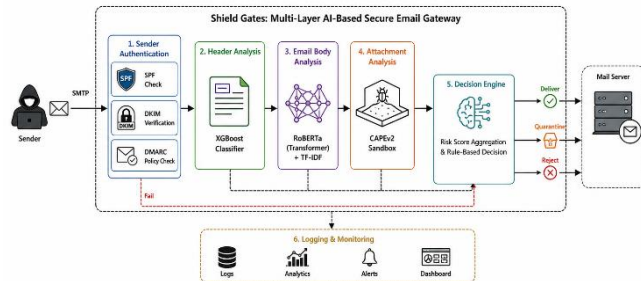


Fig. 1. Architecture of the proposed *Shield Gates* multi-layer AI-based secure email gateway

Fig. 1 illustrates the overall architecture of the proposed **Shield Gates** system. Incoming emails are first intercepted by the Secure Email Gateway, where sender authentication is verified using **SPF**, **DKIM**, and **DMARC** [6]–[8]. The

email header is analyzed using the **XGBoost** classifier [9], while the email body is processed using the **RoBERTa** model [10]. Attachments are dynamically inspected using **CAPEv2** sandboxing [11]. Finally, a centralized decision engine combines the outputs of all security layers to determine whether the email should be delivered, quarantined, or rejected.

C. Workflow

The workflow of the proposed **Shield Gates** system begins when an incoming email is intercepted by the Secure Email Gateway before reaching the internal mail server. The system first performs sender authentication by validating **SPF**, **DKIM**, and **DMARC** records [6]–[8] to verify the legitimacy of the sender and detect email spoofing attempts. After successful authentication, the email header is processed using the **XGBoost** classifier [9], which extracts and evaluates header features to identify suspicious characteristics. Simultaneously, the email body is analyzed using the **RoBERTa** model [10] combined with **TF-IDF** feature extraction to identify phishing-related language and deceptive content. If the email contains attachments, they are executed in an isolated **CAPEv2** sandbox [11] environment to monitor their behavior and detect malicious activities. The outputs of all detection layers are then forwarded to the centralized decision engine, where individual risk scores are aggregated and evaluated using predefined security rules. Based on the final assessment, the system decides whether the email should be delivered safely to the recipient, quarantined for further inspection, or rejected to prevent potential phishing attacks. This sequential workflow enables efficient multi-layer analysis while maintaining high detection accuracy and minimizing false positive rates.

IV. METHODOLOGY

A. Header Authentication

The first stage of the proposed methodology focuses on verifying the authenticity of incoming emails using the three standard email authentication protocols: **SPF**, **DKIM**, and **DMARC** [6]–[8]. **SPF** is used to verify whether the sender's IP address is authorized to send emails on behalf of the specified domain. **DKIM** validates the integrity of the email by verifying the digital signature attached to the message, ensuring that its content has not been modified during transmission. **DMARC** complements these mechanisms by defining domain-level policies and specifying how emails that fail **SPF** or **DKIM** verification should be handled. The authentication results generated during this stage serve as the first security layer and are forwarded to the decision engine for further analysis.

B. Header Analysis

After authentication, the email header is analyzed using a machine learning-based classification approach. Relevant header features, including sender information, routing paths, authentication results, and metadata, are extracted and processed before being passed to the **XGBoost** classifier [9]. **XGBoost** was selected due to its high classification accuracy, computational efficiency, and ability to handle structured data

effectively. The classifier evaluates the extracted features and generates a phishing probability score, which represents the likelihood that the email is malicious. This score is then forwarded to the centralized decision engine, where it is combined with the outputs of the remaining detection layers.

C. Email Body Analysis

The textual content of each email is analyzed using a hybrid natural language processing (NLP) approach that combines **RoBERTa** [10] with **TF-IDF** feature extraction. Before classification, the email body undergoes preprocessing, including text normalization and cleaning. TF-IDF is applied to capture important keyword frequencies, while RoBERTa extracts contextual semantic representations to better understand the meaning of the email. The combined approach enables the system to identify phishing indicators that may not be detected using traditional keyword-based methods alone. The generated phishing confidence score is then forwarded to the centralized decision engine for final evaluation.

D. Attachment Analysis

If an email contains one or more attachments, they are dynamically analyzed using the **CAPEv2** sandbox [11]. Instead of relying solely on static signature-based detection, CAPEv2 executes attachments in an isolated virtual environment and monitors their runtime behavior. During execution, the sandbox records system calls, process creation, registry modifications, network activity, and other behavioral indicators associated with malware. Based on the observed behavior, the sandbox determines whether the attachment is benign or malicious and produces a behavioral analysis report. This dynamic inspection significantly improves the detection of previously unseen or obfuscated malware that may evade traditional antivirus solutions.

E. Decision Engine

The final stage of the proposed methodology is the centralized decision engine, which integrates the outputs produced by all previous detection layers. Authentication results, header classification scores, email body analysis results, and attachment sandbox reports are aggregated to calculate the overall risk level of each incoming email. The decision engine applies predefined security policies together with adaptive risk scoring to determine the appropriate action. Emails classified as legitimate are delivered to the recipient's mailbox, suspicious emails are quarantined for further inspection, and malicious emails are rejected before reaching the internal mail server. By combining multiple complementary security mechanisms, the decision engine reduces false positives while improving the overall robustness and reliability of the proposed Shield Gates Secure Email Gateway.

V. RESULTS AND DISCUSSION

A. Experimental Results

TABLE I. PERFORMANCE EVALUATION RESULTS

<i>Metric</i>	<i>Training</i>	<i>Testing</i>	<i>Validation</i>
ROC-AUC	0.9994	0.9986	0.9984
F1-score	0.9851	0.9735	0.9754
Precision	0.9935	0.9836	0.9868
Recall	0.9768	0.9636	0.9642

The proposed **Shield Gates** system was evaluated using a three-stage experimental setup consisting of **60% training**, **20% testing**, and **20% validation** on a balanced dataset containing **14,510** email samples. As shown in **Table I**, the proposed framework achieved consistently high performance across all evaluation stages. During the validation phase, the system achieved a **ROC-AUC** score of **0.9984**, an **F1-score** of **0.9754**, a **Precision** of **0.9868**, and a **Recall** of **0.9642**. These results demonstrate the effectiveness of combining sender authentication, machine learning, natural language processing, and dynamic attachment analysis within a unified Secure Email Gateway.

B. Performance Analysis

The experimental results demonstrate the effectiveness of the proposed **Shield Gates** framework in detecting phishing emails under realistic conditions. The consistently high performance across the training, testing, and validation datasets indicates that the proposed model generalizes well without significant overfitting. The achieved **ROC-AUC** score of **0.9984** confirms the system's strong capability to distinguish between phishing and legitimate emails. Moreover, the high **Precision** and **Recall** values demonstrate that the integration of **SPF**, **DKIM**, **DMARC**, **XGBoost**, **RoBERTa**, and **CAPEv2** enables accurate phishing detection while maintaining a low false positive rate. These findings highlight the effectiveness of the proposed multi-layer architecture for practical enterprise email protection.

C. Comparison with Existing Studies

TABLE II. COMPARISON WITH EXISTING STUDIES

<i>Study</i>	<i>Accuracy</i>	<i>Header Authentication</i>	<i>NLP</i>	<i>Sandbox</i>	<i>Email Gateway</i>
Zhang et al. [1]	99.968%	✗	✓	✗	✗
Chang et al. [2]	98.10%	✗	✓	✗	✗
Qi et al. [4]	99.45%	✗	✗	✗	✗
Dewis & Viana [5]	99.00%	✗	✓	✗	✗
Proposed Shield Gates	99.68%	✓	✓	✓	✓

Table II compares the proposed **Shield Gates** framework with representative phishing email detection approaches reported in the literature. While previous studies achieved high classification accuracy, most of them focus on a limited number of detection techniques. In contrast, the proposed system integrates sender authentication, natural language processing, dynamic attachment sandboxing, and Secure Email Gateway protection within a unified architecture. This combination enables comprehensive phishing detection while maintaining competitive classification performance, making the proposed framework more suitable for real-world enterprise email security.

VI. CONCLUSION

This paper presented Shield Gates, a multi-layer AI-based Secure Email Gateway designed to protect enterprise email systems against phishing attacks. The proposed framework integrates sender authentication using SPF, DKIM, and DMARC [6]–[8], machine learning-based header analysis with XGBoost [9], natural language processing using RoBERTa [10] and TF-IDF, and dynamic attachment inspection through the CAPEv2 sandbox [11]. Experimental evaluation demonstrated that the proposed framework achieves high phishing detection performance while maintaining a low false positive rate, making it suitable for practical deployment in enterprise environments. Future work will focus on improving the detection of zero-day phishing attacks, integrating large language models for contextual email analysis, and enhancing real-time detection capabilities through adaptive threat intelligence.

REFERENCES

- [1] H. Zhang, Y. Shi, M. Liu, L. Chen, S. Wu, and Z. Xue, "A Combined Feature Selection Approach for Malicious Email Detection Based on a Comprehensive Email Dataset," *Cybersecurity*, vol. 8, no. 1, Art. no. 14, Feb. 2025, doi: **10.1186/s42400-024-00309-6**.
- [2] C. C. Chang, M. N. Al-Andoli, and C. Zheng, "Hybrid Phishing Detection Model: Integrating BERT with TF-IDF for Enhanced Email Security," *International Journal of Robotics and Automation Sciences (IJORAS)*, vol. 7, no. 3, pp. 43–48, 2025, doi: **10.33093/ijoras.2025.7.3.6**.
- [3] A. Alhuzali, A. Alloqmani, M. Aljabri, and F. Alharbi, "In-Depth Analysis of Phishing Email Detection: Evaluating the Performance of Machine Learning and Deep Learning Models Across Multiple Datasets," *Applied Sciences*, vol. 15, no. 6, Art. no. 3396, 2025, doi: **10.3390/app15063396**.
- [4] Q. Qi, Z. Wang, Y. Xu, Y. Fang, and C. Wang, "Enhancing Phishing Email Detection through Ensemble Learning and Undersampling," *Applied Sciences*, vol. 13, no. 15, Art. no. 8756, 2023, doi: **10.3390/app13158756**.
- [5] M. Dewis and T. Viana, "Phish Responder: A Hybrid Machine Learning Approach to Detect Phishing and Spam Emails," *Applied System Innovation*, vol. 5, no. 4, Art. no. 73, 2022, doi: **10.3390/asi5040073**.
- [6] S. Kitterman, "Sender Policy Framework (SPF) for Authorizing Use of Domains in Email, Version 1," RFC 7208, Internet Engineering Task Force (IETF), Apr. 2014, doi: 10.17487/RFC7208.
- [7] D. Crocker, T. Hansen, and M. Kucherawy, "DomainKeys Identified Mail (DKIM) Signatures," RFC 6376, Internet Engineering Task Force (IETF), Sept. 2011, doi: 10.17487/RFC6376.
- [8] M. Kucherawy and E. Zwicky, "Domain-based Message Authentication, Reporting, and Conformance (DMARC)," RFC 7489, Internet Engineering Task Force (IETF), Mar. 2015, doi: 10.17487/RFC7489.
- [9] T. Chen and C. Guestrin, "XGBoost: A Scalable Tree Boosting System," in Proc. 22nd ACM SIGKDD Int. Conf. Knowledge Discovery and Data Mining (KDD '16), San Francisco, CA, USA, Aug. 2016, pp. 785–794, doi: 10.1145/2939672.2939785.
- [10] Y. Liu, M. Ott, N. Goyal, J. Du, M. Joshi, D. Chen, O. Levy, M. Lewis, L. Zettlemoyer, and V. Stoyanov, "RoBERTa: A Robustly Optimized BERT Pretraining Approach," arXiv:1907.11692, 2019, doi: 10.48550/arXiv.1907.11692.
- [11] CAPEv2 Team, "CAPEv2: Malware Configuration and Payload Extraction," GitHub Repository. [Online]. Available: <https://github.com/kevoreilly/CAPEv2>